XYZ · **Technology Services**

Information Security Policy

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

Document Number: XYZ-TS-IS-PO-001

Classification: Internal

Owner: Chief Digital Officer (CDO)

Version: V 2.0

Effective Date: 15-Sep-2021

Document History:

Release Date	Revision No	Author	Description	Reviewed & Approved By	Next review date
15-Sep-2021	1.0	ISO	Approved Document	ISMC	Sep-2022
03-Feb-2022	1.1	ISO	Approved Document *(Password Policy Exceptions are included)*	ISMC	Sep-2022
20-Sep-2022	1.1	ISO	Annual Review	ISMC	Sep-2023
05-Sep-2023	1.1	ISO	Annual Review	ISMC	Sep-2024
15-Febr-2024	1.2	ISO	Amendments to the password policy	ISMC	Sep-2024
01-Mar-2025	2.0	ISO	Amendments done as per ISO 27001:2022	ISMC	Mar-2025

CS5292 W6 · D04 · sanitised for teaching

Contents

1 Purpose 1

1.1 Policy Document Management 1

1.2 Distribution 1

1.3 Enforcement 1

1.4 Exceptions 1

1.5 ISMS Manual Review 1

2 Scope 2

3 Definitions 2

4 Information Security Policies 4

4.1 Management Direction for Information Security 4

4.2 Information Security at XYZ-TS 4

4.3 Information Security Policy Statement 5

5 Organizational Controls 6

5.1 Purpose 6

5.2 Responsibility 6

5.3 Policies of Information Security 6

5.4 Information Security Roles and Responsibilities 6

5.5 Segregation of Duties 6

5.6 Management Responsibilities 7

5.7 Contact with Authorities 7

5.8 Contact with Special Interest Groups 7

5.9 Threat Intelligence 7

5.10 Information Security in Project Management 7

5.11 Inventory of Information and Other Associated Assets 8

5.12 Acceptable Use of Information and Other Associated Assets 8

5.13 Return of Assets 8

5.14 Classification of Information 9

5.15 Labeling of Information 9

5.16 Information Transfer 9

5.17 Access control 10

5.18 Identity Management 11

5.19 Authentication Information 11
5.20 Access Rights 12
5.21 Information Security in Supplier Relationships 12
5.22 Addressing Information Security within Supplier Agreements 12
5.23 Managing Information Security in the Information and Communication Technology (ICT) Supply Chain 13
5.24 Monitoring, Review, and Change Management of Supplier Services 14
5.25 Information Security for Use of Cloud Services 15
5.26 Information Security Incident Management Planning and Preparation 15
5.27 Assessment of and Decision on Information Security Events 16
5.28 Response to Information Security Incidents 16
5.29 Learning from Information Security Incidents 17
5.30 Collection of Evidence 17
5.31 Information Security During Disruption 17
5.32 ICT Readiness for Business Continuity 17
5.33 Legal, Statutory, Regulatory and Contractual Requirements 18
5.34 Intellectual Property Rights 18
5.35 Protection of Records 18
5.36 Privacy and Protection of Personally Identifiable Information 18
5.36.1 Use of Personnel Information 19
5.36.2 Prevention of misuse of information processing facilities 19
5.36.3 Other Applicable Legislations 19
5.37 Independent Review of Information Security 20
5.38 Compliance with Policies, Rules, and Standards for Information Security 20
5.39 Documented Operating Procedures 21
6 People Controls 21
6.1 Purpose 21
6.2 Responsibility 21
6.3 Screening 22
6.4 Terms and Conditions of Employment 22
6.5 Information Security Awareness, Education and Training 22
6.6 Disciplinary Process 23
6.7 Responsibilities After Termination or Change of Employment 23

6.8 Confidentiality or Non-Disclosure Agreements 23
6.9 Remote Working 24
6.10 Information Security Event Reporting 24
7 Physical Controls 25
7.1 Physical Security Perimeters 25
7.2 Physical Entry 25
7.3 Securing Offices, Rooms, and Facilities 26
7.4 Physical Security Monitoring 26
7.5 Protection Against Physical and Environmental Threats 27
7.5.1 Protection from External Threats 27
7.5.2 Protection from Fire 27
7.5.3 Protection from Water Damage 27
7.5.4 Power, Air-conditioning, and Other Supporting Utilities 27
7.6 Working in Secure Areas 28
7.7 Clear Desk and Clear Screen Policy 28
7.8 Equipment Siting and Protection 29
7.9 Security of Assets Off-Premises 29
7.10 Storage Media 29
7.11 Supporting Utilities 29
7.12 Cabling Security 29
7.13 Equipment Maintenance 30
7.14 Secure Disposal or Re-Use of Equipment 30
8 Technological Controls 30
8.1 User Endpoint Devices 30
8.2 Privileged Access Rights 30
8.3 Information Access Restriction 31
8.3.1 XYZ-TS Password Policy – User Level Password Policy 31
8.3.2 XYZ-TS Password Policy – Administrative Level Password Policy 32
8.3.3 XYZ-TS Password Policy – Exemptions 32
8.4 Access to source code 32
8.5 Secure authentication 33
8.6 Capacity Management 33

8.7 Protection Against Malware 34
8.7.1 Detection 34
8.7.2 Employee Responsibility 34
8.8 Management of Technical Vulnerabilities 35
8.8.1 Patch Management 35
8.9 ICT Configuration Management 36
8.10 Information Deletion 36
8.11 Data Masking 36
8.12 Data Leakage Prevention 36
8.13 Information Backup 36
8.14 Redundancy of information processing facilities 36
8.15 Logging 37
8.15.1 Review of Logs 37
8.15.2 Monitoring System Use 37
8.16 Monitoring Activities 38
8.17 Clock Synchronization 38
8.18 Use of Privileged Utility Programs 38
8.19 Installation of Software on Operational Systems 38
8.20 Network Security 39
8.20.1 Access to Network Infrastructure and Utilities 39
8.20.2 General Network Management Controls 39
8.20.3 Network Infrastructure Management Controls 39
8.21 Security of Network Services 40
8.22 Segregation in Networks 40
8.23 Web filtering 40
8.24 Use of Cryptography 40
8.25 Secure Development Life Cycle (N/A) 41
8.26 Application Security Requirements (N/A) 41
8.27 Secure System Architecture and Engineering Principles (N/A) 42
8.28 Secure Coding (N/A) 42
8.29 Security Testing in Development and Acceptance (N/A) 42
8.30 Outsourced Development 42
8.31 Separation of Development, Test, and Production Environments (N/A) 42

8.32 Change Management 43
8.33 Test Information (N/A) 43
8.34 Protection of Information Systems During Audit Testing 44
9 Version History Control 44
10 Non-adherence and Disciplinary Action 44

1 Purpose

This manual defines information security and describes management's commitment to safeguarding information at XYZ Technology Services (hereafter referred to as "XYZ-TS") and the obligation of the employees, contractors, and third parties to perform such duty.

1.1 Policy Document Management

Information Security Management System Manual Part I and Part II in combination will make the information security management system manual. Information Security Management System Manual – Part II is issued under the XYZ-TS ***Mandatory ISMS Procedures*** (XYZ-TS-IS-PR-002).

1.2 Distribution

This is an internal document and should only be shared with employees at XYZ-TS and intended parties determined by the Chief Digital Officer (CDO).

1.3 Enforcement

All employees, stakeholders, and third-party vendors having access to information and information systems of XYZ-TS shall comply with the XYZ-TS Information Security Policy. Such personnel should be required to execute an agreement with XYZ-TS agreeing to abide by the Policy.

1.4 Exceptions

Approval for exceptions or deviations from the policies, wherever warranted, will be provided only after an appropriate assessment of the risks arising out of providing the exception. This assessment will be conducted by the Information Security Management Committee (ISMC).

Exceptions will be agreed on a case-by-case basis, upon an official request made by the information asset owner or the user. These may arise, for example, because of local circumstances, conditions, practical limitations, or legal reasons existing at any point in time. All exceptions must be submitted to the ISMC.

Approval for the exception will be provided by ISMC. The CDO will review all exceptions every year for validity and continuity.

1.5 ISMS Manual Review

The ISMS Manual and all the policies will be reviewed once in a year or as per the requirement arises in the organizational structure or roles and responsibilities of the ISMS are affected. Review shall incorporate changes in business objectives or the risk environment.

The review document will follow the document change management process as outlined in Procedure for XYZ-TS ***Mandatory ISMS Procedures*** (XYZ-TS-IS-PR-002).

CS5292 W6 · D04 · sanitised for teaching

2 Scope

Scope of ISMS shall be as per the latest version of ***ISMS Scope Document*** (XYZ-TS-IS-MN-001).

3 Definitions

Availability	Availability is a characteristic that applies to assets. An asset is available if it is accessible and usable when needed by an authorized entity. Assets include things like information, systems, facilities, networks, and computers. All of these assets must be available to authorized entities when they need to access or use them.
Confidentiality	Confidentiality is a characteristic that applies to information. To protect and preserve the confidentiality of information means to ensure that it is not made available or disclosed to unauthorized entities. In this context, entities include both individuals and processes.
Information Asset	Information Asset is a definable piece of information, stored in any manner which is recognized as 'valuable' to the organization.
Information Asset Owner	The information asset owner has the responsibility of classifying the asset on the basis of XYZ-TS's asset classification scheme and related guidelines. The owner of the information asset shall identify and approve the controls to be implemented to provide appropriate protection to the asset. In addition, the asset owner should annually review the access control policies and classification processes. The owner of the information asset is accountable for the security of the information asset.
Information Security	Information security is the protection of information from a wide range of threats in order to ensure business continuity, minimize business risk, and maximize return on investments and business opportunities.
Information Security Event	An information security event indicates that the security of an information system, service, or network may have been breached or compromised. An information security event indicates that an information security policy may have been violated, or a safeguard may have failed.
Information Security Incident	An information security incident is made up of one or more unwanted or unexpected information security events that could very likely compromise the security of your information and weaken or impair your business operations.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

Information Security Management System (ISMS)	Information Security Management System (ISMS) refers to a set of policies and processes established by management to assess the security requirements, develop and implement controls, evaluate effectiveness of
	controls and implement improvements following a Plan-Do-Check-Act continuous improvement process.
Information Security Management System Auditor (ISMSA)	The Information Security Management System Auditor (ISMSA) performs periodic audits of XYZ-TS Information Security Management System and related processes.
Integrity	To preserve the integrity of information means to protect the accuracy and completeness of information and the methods that are used to process and manage it.
Malicious Code	Malicious code includes all and any programs (including macros and scripts) which are deliberately coded in order to cause an unexpected (and usually, unwanted) event on an IT system.
Vulnerability	Vulnerability is a weakness in an information asset or group of information assets. An information asset's weakness could allow it to be exploited and harmed by one or more threats.
Security features of network services	Security features of network services could be: Technology applied for security of network services, such as authentication, encryption and network connection controls. Technical parameters required for secured connection with the network services by the security and network connection rules; and Procedures for the network service usage to restrict access to network services or applications
Media	Storage media that contains XYZ-TS information.
Service Level Agreements (SLA)	A contract between two parties that specifies, usually in measurable terms, what services will be furnished.
Change Management	Procedure of controlling changes to the infrastructure, or any aspect of services in a controlled manner enabling approved changes with minimum disruptions.
Information Security Incident Management	Processes for detecting, reporting, assessing, responding to, dealing with, and learning from information security incidents.
Risk Assessment	Overall process of risk identification, risk analysis, and risk evaluation.

Further, the terms and definitions given in ISO-IEC 27000 apply.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

4 Information Security Policies

4.1 Management Direction for Information Security

XYZ Technology Services Information Security objectives

1. Continuously follow the risk management process to identify and mitigate the information security risk related to the XYZ-TS information processes.
2. Ensure the effectiveness of Disaster Recovery by reviewing and testing promptly.
3. Maintain an appropriate level of awareness, knowledge and skills to minimize the occurrence and severity of information security incidents at XYZ-TS.
4. Maintain an effective information security incident management process to timely respond to security incidents and minimize such incidents;"
5. Maintaining compliance with any applicable legal, regulatory, statutory and contractual obligations while preserving XYZ-TS reputation.
6. Provide a secure and better service for XYZ employees and its stakeholders.

XYZ-TS will achieve the information security objectives by:

- Working as a team.
- Approaching with commitment.
- Following work ethics.
- Ensuring compliance; and
- Establishing best practices.

4.2 Information Security at XYZ-TS

Information is a key asset of XYZ-TS and needs to be protected. Information can be stored in the form of written, printed, or electronic media or people. With the increase in interconnectivity, information is exposed to many threats and vulnerabilities. Information Security is the protection of information from threats and vulnerabilities to prevent unauthorized disclosure of information and preserve confidentiality, maintain integrity, ensure business continuity, and minimize business risk to maximize return on investment.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

We at XYZ-TS are committed to protecting the information and information processing assets or facilities of all our stakeholders, providing information security awareness to team members and ensuring continual improvement in information security in all our IT activities-processes while meeting applicable business, legal or regulatory and customer requirements through regular review of our Information Security Management System.

4.3 Information Security Policy Statement

XYZ-TS ***provides IT services for*** XYZ ***business units and supports enhancing the business process by being a technology enabler while preserving the security of the information assets and customer information.***

Within the context of this policy, the term "Security" about information shall mean the safeguard of Confidentiality, Integrity and Availability properties of the information and information assets, as per the following definitions:

- **Confidentiality - Information should not be made available or be disclosed to unauthorized entities (i.e. persons, organizations, and systems);**
- **Integrity - Reliability of information will be maintained through protection from unauthorized, unintended modifications during transmission, storage, and retrieval; and**
- **Availability - Authorized users are granted timely and uninterrupted access to information. Availability will be based on the business requirements of the user.**

To preserve the information security requirements, ensure compliance with contractual obligations, and provide better and secure service to XYZ business units and customers, XYZ-TS is committed to improving the efficiency of IT infrastructure and assuring the security of its information assets at all times through effective implementation and operation of an ISMS. Therefore, this information security policy of XYZ-TS dictates great responsibility to all stakeholders to protect the information assets of XYZ-TS.

XYZ-TS shall strive to secure information, safeguard information - IT assets and develop efficient information systems by maintaining an effective information security posture at XYZ-TS while being compliant with applicable legal, regulatory, and contractual requirements.

To meet the information security objectives of the organization, XYZ-TS shall establish, operate, and maintain ISMS aligned with the requirements of the ISO-IEC 27001:2022 standard and leading practice guidelines. A risk management framework shall also be defined to analyze, assess, and treat information security risks. The ISMS shall be implemented through a set of policies, procedures, and standards, mandated by ISMC and communicated to all employees, temporary staff and third-party contractors.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

5 Organizational Controls

5.1 Purpose

The purpose of this policy is to define a suitable information security organization structure, and roles and responsibilities for coordination of information security activities across the organization.

5.2 Responsibility

The senior management of XYZ-TS representing ISMC will be responsible for implementing this policy by identifying adequate resources and assigning specific security roles to individuals with proper competency and training.

5.3 Policies of Information Security

The set of XYZ-TS information security policies relevant to operating the ISMS and achieving the above policy statement is set out in this manual.

This policy will be reviewed by ISM and updated once a year (annually) to incorporate any additions, modifications, or deletions to policies and controls that may be required due to changes, including but not limited to technology, regulations and contractual requirements. However routine reviews shall occur if any significant change arises in the XYZ-TS's technical or business environment.

5.4 Information Security Roles and Responsibilities

The roles and responsibilities of ISMC, the individual roles representing the ISMC and other roles supporting the ISMS are documented in the XYZ-TS ***ISMS Roles and Responsibilities*** (XYZ-TS-IS-PR-***018)*** and ***ISMC Terms of Reference*** (XYZ-TS-IS-MN-003)

5.5 Segregation of Duties

All XYZ-TS processes must adopt the principle of segregation of duties to the maximum extent possible. That shall constitute:

- Persons involved in operational functions must not be given additional responsibilities in XYZ-TS administration processes and vice versa.
- Persons shall not be able to approve functions performed by their superiors.
- Where segregation of duties is not possible or practical, the process must include compensating controls; such as monitoring of activities, maintenance and review of audit trails, and management supervision.
- XYZ-TS administrators shall not be directly involved with audit- investigation and disciplinary actions.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

- Monitoring processes shall be implemented to determine if any conflicting actions occur.

5.6 Management Responsibilities

The IS Officer is responsible for ensuring that all users including staff and third parties adhere to information security policies and procedures.

5.7 Contact with Authorities

CDO, leadership team members or relevant nominees from upper management shall coordinate with appropriate authorities (e.g. law enforcement, fire department, municipal authorities, and telecommunication providers).

5.8 Contact with Special Interest Groups

Special interest groups or other specialist security forums and professional associations in order to improve knowledge of best practices, to be up to date with relevant security information and to provide suitable liaison points when dealing with information security incidents.

5.9 Threat Intelligence

The SOC and the IS Officer shall subscribe to a reliable cyber threat intelligence feed, collect the required information on cyber security threats, process the information collected analyze the risk, and provide an adequate mitigation plan to prevent cyber security risk for XYZ - TS IT infrastructure.

The SOC shall analyze the feeds to check their applicability to the technology environment of XYZ-TS and take preventive actions to mitigate the threats promptly.

5.10 Information Security in Project Management

Information security shall be addressed in project management, regardless of the type of the project.

Information security shall be integrated into XYZ-TS's project management method(s) to ensure that information security risks are identified and addressed as part of a project. This applies generally to any project regardless of its character, *e.g. a project for a core business process, IT, facility management and other supporting processes*.

The project management methods shall include:

- Information security objectives in project objectives;
- An information security risk assessment conducted at an early stage of the project to identify necessary controls;

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

- Information security as part of all possible phases of the applied project methodology.
- Information security implications shall be addressed and reviewed regularly in all projects. Responsibilities for information security shall be defined and allocated to specified roles defined in the project management methods.

5.11 Inventory of Information and Other Associated Assets

Process Owners/Line Managers are responsible for preparing and maintaining information asset inventories within the scope of the ISMS. This should include all information assets within the scope of the ISMS.

IS Officer shall define a process of identifying and inventorying information assets. This process shall be followed by process owners/ line managers.

Based on the defined information asset identification process the owners of each information asset shall be identified.

The asset owners shall be responsible for:

- Ensuring that the information assets are appropriately classified;
- Determine the access list for the asset; and
- Implement appropriate safeguard controls for the asset

For further details, please refer to the Information Asset Management Procedure.

5.12 Acceptable Use of Information and Other Associated Assets

Rules-standards are defined for the acceptable use of information and assets associated with information processing facilities shall be initiated and implemented.

All XYZ-TS employees and any third-party service providers who have access to XYZ-TS information or information systems shall follow rules for the acceptable use of information and assets associated with information processing facilities. The rules and guidelines of acceptable usage are included in the XYZTS-IS-PO-002-XYZ-TS ***IT Usage Policy.***

5.13 Return of Assets

HR division in collaboration with XYZ TS shall ensure that all assets of the organization e.g. ID cards, and laptops are returned by the outgoing employee, service providers, and contracted employees upon termination of their contract or at the end of employment.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

5.14 Classification of Information

Information shall be classified in terms of its value, legal requirements, sensitivity, criticality, and other requirements to XYZ - TS.

The information owners shall classify the information as per the classification procedures of XYZ - TS.

The security classification level of the information shall be identified based on the impact faced by the business if confidentiality, integrity, or availability is breached.

All information shall be classified to specify its level of sensitivity or confidentiality to protect sensitive information. The Information Owner of the document or information owner must assign appropriate classification. Every piece of information shall have an Information Owner. The Information Owner is the person holding the highest position in the relevant area.

The Information Owner shall specify a list of users that are allowed to access information, which lists names of persons, designations, groups or roles, or names of companies that are authorized to view or modify the information where applicable.

Classification of the information in physical form shall be in all the documentation making it visible.

For further details, please refer to the Information Asset Management Procedure.

5.15 Labeling of Information

Information assets shall carry an appropriate labeling to reflect its sensitivity and importance to XYZ - TS and handle the asset as per its sensitivity and importance.

For further details, please refer to the Information Asset Management Procedure.

5.16 Information Transfer

Appropriate controls shall be implemented for protection against malicious code while transmitting information electronically.

Sensitive information shall be protected using encryption, password or any other suitable method especially when being sent as an attachment in an email.

Disposal procedures shall be followed to destroy sensitive information.

End users will:

- Do Not leave sensitive information unattended at fax machines, printers, etc.
- Not auto-forward mails to external mail IDs.
- Not reveal sensitive information in public.
- Not leave sensitive messages on answering machines.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

- Check the recipient's email id before sending an email.

In case of an exchange of information between XYZ-TS and an external party, an appropriate agreement shall be established addressing the following points:

- Traceability and non-repudiation;
- Courier identification standards;
- Responsibilities and liabilities in the event of an incident; • Labelling system as per the sensitivity of the information; and
- Cryptography.

Information present in electronic messages shall be appropriately protected according to its criticality.

5.17 Access control

The creation changes and termination of user access rights and associated privileges shall be controlled and monitored. Processes shall be established to ensure that this is done by the Access Control policy.

Users shall be assigned a unique ID before being allowed to access system components. In addition to assigning a unique ID, at least one of the following methods shall be used to authenticate users;

- Something you know, such as a password or passphrase;
- Something you have, such as a token device or smart card; or
- Something you are, such as a biometric.

Access to the information systems will not be granted unless the authorization procedure has been completed.

Explicit approval from authorized parties is required to use critical technology systems.

Use of technology shall be authenticated with user ID and password or other authentication item.

Access shall be restricted to the least privileges necessary to perform job responsibilities.

Access privileges are assigned to individuals based on job classification and function on a need-to-know basis.

Access rights of all users who have changed roles or have left the organization shall be revoked immediately.

User IDs that (Active Directory) are inactive for more than 90 days shall be deactivated after getting confirmation from relevant administrators and the HR department. The last login date shall be considered to determine the inactive period.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

If the access is granted for a defined period (in the case of vendors, temporary employees, etc.), an automatic expiry date shall be configured at the access creation to ensure the access will be disabled at the time when the respective users' duties are complete.

A formal authorization procedure shall be followed to allow access to networks and network services.

Access to networked services such as servers, printers, etc. shall be provided to users as per the access control policy. Additional controls such as secure Virtual Private Network (VPN) tunnels shall be used to access remote network services.

XYZ-TS NOC Team shall ensure that its network will not be interconnected with any un-trusted voice or data network unless appropriately configured firewalls and other suitable protection measures are in place.

The NOC Team shall ensure that access to the Internet is controlled via access control.

5.18 Identity Management

Users shall be assigned a unique ID before being allowed to access system components.

For each unique ID, appropriate user authentication methods shall be established.

Identities assigned to XYZ - TS staff must be unique and shall be able to hold accountability for the staff /users for the actions carried out using the account.

The IS Officer must approve shared accounts/identities, and the requestor must provide a clear business justification for such approval.

Shared account usage must be restricted where possible.

Service accounts or identities assigned to non-human entities must be identified and documented for their usage and which applications/ processes are using these accounts. Further, every service account must have a custodian who knows about the usage of the accounts and usage of credentials.

All accounts including shared accounts and services must undergo the user access review.

For further details, please refer to the System Access Control Procedure.

5.19 Authentication Information

All users shall be required to keep personal passwords confidential.

All newly created user IDs shall be assigned a temporary password which shall be changed immediately upon first login.

Any user requesting a password change shall be duly verified.

The exchange of temporary passwords shall be carried out securely.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

Default vendor passwords shall be changed or disabled following the installation of the system or software.

The job description for all positions shall be documented by the respective business unit. Security roles and responsibilities which are part of the same are provided. These responsibilities shall include any general responsibilities for implementing or maintaining security policy as well as any specific responsibilities for the protection of particular assets or the execution of particular security processes or activities.

5.20 Access Rights

User access rights shall be changed after any change in employment of the user such as promotion, demotion, or termination.

Privileged user access rights (i.e. System Engineers) shall be reviewed.

Any modifications for existing user access rights will be approved by the relevant process owner and communicated to the relevant administrators for implementation.

5.21 Information Security in Supplier Relationships

Manager – Central IT Sourcing shall be responsible to conduct a risk assessment to identify potential risks to XYZ-TS's Information Security as a result of service provisioning through third party. This shall be carried out with the assistance of the respective project managers.

This risk assessment should consider the following criteria:

- The type of information or data processing functions or services to be accessed by the third party;
- The risk classification of the information or data processed by the systems that third party will be working with; and
- Background information about the third party.

Based on the risk assessment results, information security requirements for mitigating the risks associated with supplier's access to the organization's assets shall be agreed with the supplier and documented in a form of an agreement.

5.22 Addressing Information Security within Supplier Agreements

Supplier contracts must be consistent in all respects with XYZ-TS's Information Security Policies and Procedures.

Supplier contracts must include the following conditions, as applicable:

- Description of the information to be provided or accessed;
- The level of physical and logical security that will be provided to maintain the confidentiality, integrity and availability of the information to be provided or accessed;

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

- Classification of the information. Classification scheme can be XYZ-TS's information classification scheme or an acceptable scheme agreed by both parties;
- The service level to be provided and the level of availability in the event of a disaster;
- Provision for confidentiality, non-disclosure and acceptable use relating to the information -data processed by the outsourced function or service;
- legal and regulatory requirements, including data protection, intellectual property rights and copyright, and a description of how it will be ensured that they are met;
- Rules of acceptable use of information, including unacceptable use if necessary;
- Information security policies relevant to the specific contract;
- Incident management requirements and procedures (especially notification and collaboration during incident remediation);
- Training and awareness requirements for specific procedures and information security requirements, e.g. for incident response, authorization procedures;
- Relevant regulations for sub-contracting, including the controls that need to be implemented;
- Relevant agreement partners, including a contact person for information security issues;
- Right to audit the supplier processes and controls related to the agreement;
- Defect resolution and conflict resolution processes;
- Supplier's obligation to periodically deliver an independent report on the effectiveness of controls and agreement on timely correction of relevant issues raised in the report;
- Supplier's obligations to comply with the organization's security requirements;
- Personal screening process for the outsourced staff; and
- Continuity arrangements.

5.23 Managing Information Security in the Information and Communication Technology (ICT) Supply Chain

In certain circumstances XYZ-TS supplier may hire another subcontracting party to deliver services required. In such a situation it is the responsibility of the main supplier to indicate their supplier chain to XYZ-TS prior to signing the agreements.

In such situation XYZ-TS shall assess the risk of supplier sub-contracting the services hence risk management plan should be devised accordingly.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

The respective project manager shall validate the sub-contracting party also a known party and a verification of the vendor shall also be carried out.

Following shall be considered for inclusion in supplier agreements concerning supply chain (suppliers of the supplier) security, as applicable:

- It is the responsibility of the supplier (whom XYZ-TS is signing the agreement with) to ensure that the sub-contractors are aligning to the information security requirements of XYZ-TS. This shall be stated in the agreement clearly and supplier will be held responsible for any violations if occurred;
- A monitoring process on how XYZ-TS will validate the delivered information and communication technology products and services are adhering to stated conditions in the agreement; and
- Applicability of the NDA and right to audit for the sub-contractor.

5.24 Monitoring, Review, and Change Management of Supplier Services

Supplier services shall be monitored and reviewed on a timely basis by XYZ-TS .

This should involve a service management relationship process between XYZ-TS and the supplier to:

- Monitor service performance levels to verify adherence to the agreements;
- Review service reports produced by the supplier and arrange regular progress meetings as required by the agreements;
- Conduct audits of suppliers, in conjunction with review of independent auditor's reports, if available, and follow-up on issues identified;
- Provide information about information security incidents and review this information as required by the agreements and any supporting guidelines and procedures;
- Review supplier audit trails and records of information security events, operational problems, failures, tracing of faults and disruptions related to the service delivered;
- Resolve and manage any identified problems;

  Review information security aspects of the supplier's relationships with its own suppliers; and Ensure that the supplier maintains sufficient service capability together with workable plans designed to ensure that agreed service continuity levels are maintained following major service failures or disaster.

Any changes to the contract shall be managed depending on the criticality of the service provisioning.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

Changes shall undergo a risk assessment, considering the impact that the change would made to the existing service provisioning and information security posture. Risk treatment options should be planned accordingly and shall be addressed in the revised agreements.

5.25 Information Security for Use of Cloud Services

The Head of IT Infrastructure in coordination with the relevant stakeholders shall carry out a due diligence exercise covering information security, cyber security, and privacy requirements for cloud services obtained. This requirement shall consider prevailing legal and regulatory requirements for the same.

The Head of IT Infrastructure, in collaboration with pertinent stakeholders, shall establish the necessary information security requirements governing the utilization of cloud services. These requirements will then be formally incorporated into the service level agreement to ensure adherence by the cloud service provider.

In instances where existing agreements cannot be amended to incorporate the defined information security requirements, the IS Officer will be responsible for delineating appropriate control measures to mitigate any potential risks associated with the use of the cloud service.

For further details, please refer to the ***Cloud Onboarding and Offboarding Procedure***.

5.26 Information Security Incident Management Planning and Preparation

XYZ-TS shall establish ***IT Incident Management procedure*** (XYZ-TS-IS-PR-011) to handle different types of information security incidents.

In addition to normal contingency plans, the procedures should also cover:

- Analysis and identification of the root cause of the incident;
- Containment;

  Planning and implementation of corrective action to prevent recurrence, if necessary;
  Communication with those affected by or involved with recovery from the incident; and
- Reporting the action to the appropriate authority.

Audit trails and similar evidences shall be collected and secured, as appropriate, for:

- Internal problem analysis;
- Forensic evidence in relation to a potential breach of contract or regulatory requirement or in the event of civil or criminal proceedings; and
- Negotiating for compensation from software and service suppliers.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

Action to recover from security breaches and system failures shall be carefully and formally controlled.

The ***IT Incident Management procedure*** (XYZ-TS-IS-PR-011) shall ensure that:

- Only clearly identified and authorized personnel are allowed access to live systems and data;
- All emergency actions taken shall be in line with the approved change management policies and procedures and shall be documented in detail; and
- The integrity of business systems and controls is confirmed with minimal delay.

Responsibilities of information security incident management shall be clearly communicated to the involved parties and XYZ-TS shall ensure that those responsible for information security incident management understand the organization's priorities for handling information security incidents.

5.27 Assessment of and Decision on Information Security Events

Information security events shall be assessed, and it shall be decided if they are to be classified as information security incidents.

The point of contact shall assess each information security event using the agreed information security event and incident classification scale and decide whether the event should be classified as an information security incident. Classification and prioritization of incidents help to identify the impact and extent of an incident.

Results of the assessment and decision shall be recorded in detail for the purpose of future reference and verification.

5.28 Response to Information Security Incidents

Information security incidents shall be responded to in accordance with the ***IT Incident Management procedure*** (XYZ-TS-IS-PR-011)

Information security incidents shall be responded to by designated personnel and other relevant persons of the organization or external parties.

The response should include the following:

- Collecting evidence as soon as possible after the occurrence;
- Conducting information security forensics analysis, as required;
- Escalation, as required;
- Ensuring that all involved response activities are properly logged for later analysis;
- Communicating the existence of the information security incident or any relevant details thereof to other internal and external people or organizations with a need-to-know;

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

- Dealing with information security weakness (es) found to cause or contribute to the incident;
- Once the incident has been successfully dealt with, formally closing and recording it; and
- Post-incident analysis should take place, as necessary, to identify the source of the incident.

5.29 Learning from Information Security Incidents

All data that is collected regarding each incident shall be analyzed to identify recurring and-or high impact incidents and captured within the Information Security Event Log.

5.30 Collection of Evidence

In the event of a security incident originated by employee or third party, the associated evidence shall be collected and preserved, irrespective of whether a legal action is required or not. They are used to invoke appropriate disciplinary actions as per the HR disciplinary action procedure.

Whenever applicable, evidence shall be collected by an authorized person or a third party nominated by the management and proper chain of custody has to be maintained.

5.31 Information Security During Disruption

XYZ-TS shall determine its requirements for information security and the continuity of information security management in adverse situations, *e.g. during a crisis or disaster*.

Disaster recovery plans (DRP) shall include the information security requirements to consider during the crisis and recovery times and maintaining the continuity of information security management in adverse situations.

According to the information security continuity requirements, the organization should establish, document, implement and maintain:

- Information security controls within disaster recovery processes, procedures and supporting systems and tools;
- Processes, procedures and implementation changes to maintain existing information security controls during an adverse situation; and
- Compensating controls for information security controls that cannot be maintained during an adverse situation.

DRP testing shall also include the information security continuity testing and results shall be submitted to CSSC and ISMC.

5.32 ICT Readiness for Business Continuity

The Head of TecSecops shall plan how to maintain/recover all critical IT infrastructure during a disaster/ crisis.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

The Head of TecSecops shall ensure that the ICT Disaster Recovery Plan is in line with the business continuity objectives of XYZ - TS.

The Head of TecSecops shall ensure that this plan is in line with the business continuity plan(s).

The ICT DR plan should be tested periodically to assess the effectiveness of the plan.

5.33 Legal, Statutory, Regulatory and Contractual Requirements

XYZ-TS shall identify a list of laws, statutory, regulatory and contractual requirements applicable in relation to information security.

Applicable rules, regulations, relevant agreements, laws shall be complied while using cryptographic keys within XYZ-TS. Legal advice shall be obtained wherever required to meet these requirements.

5.34 Intellectual Property Rights

Compliance with legal restrictions shall be ensured on the use of material for which there may be intellectual property rights, such as copyrights, trademarks etc. All legislative, contractual or regulatory restrictions on the usage and copying of proprietary material shall be adhered to.

The usage and copying of software products shall be restricted as per the terms and conditions of licensing agreement. An inventory of all software product licenses shall be maintained and usage of unlicensed software in its Information System shall be strictly avoided.

5.35 Protection of Records

No cardholder data including PAN, CVV, PIN, Track Data will be stored within XYZ-TS network and systems or transmitted using end user messaging technologies.

Important records shall be protected from possible loss, destruction and tampering. A record retention schedule shall be drawn up identifying essential record types and the period of time for which the records need to be retained depending upon the statutory, regulatory or contractual requirements.

Sensitive and personally identifiable information (PII) should be sorted for a minimum duration as per mentioned retention periods and business requirements. There should be a process to securely delete data when no longer needed.

The print records shall be stored in a separate facility adequately protected by physical security and from environmental hazards. Adequate precautions shall be taken for magnetic storage media, technology obsolescence and recovery of data related issues.

5.36 Privacy and Protection of Personally Identifiable Information

XYZ-TS possesses (hosted through servers) data pertaining to its clients (associated business units), customers and its employees. Technical and organizational measures like logical access controls, nondisclosure agreements shall be implemented to protect this information and employees' personal information.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

5.36.1 Use of Personnel Information

Personal identifiable information shall only be collected and used for business purposes, and in line with relevant legislations, regulations and contractual clauses.

Personal information shall not be shared without due consent of the concerned individual or the approval of the HR department, except where XYZ-TS may be obligated to share such information with law-enforcement, government and regulatory authorities, or to prevent imminent loss or harm to the concerned individual or others.

Communications that may include personal or private information such as email, phone calls, made through XYZ-TS systems and networks, shall only be recorded and monitored in accordance with defined instructions, approvals and after informing the concerned individuals.

5.36.2 Prevention of misuse of information processing facilities

XYZ-TS's information processing facilities shall be used for business purpose only. Appropriate controls shall be implemented for preventing the usage of these facilities for non-business or unauthorized purposes. A disciplinary process shall be initiated for the inappropriate usage of XYZ-TS information processing facilities.

At the time of login, a warning message shall be displayed on the computer screen indicating that the system being entered belongs to XYZ-TS and that unauthorized access is not permitted.

5.36.3 Other Applicable Legislations

Computer Crimes Act (CCA)

XYZ-TS Personnel shall abide by the Computer Crimes Act (CCA) No 24 of 2007. In terms of this Act no person should without lawful authority access any computer or any information held in any computer, knowing that he/she has no lawful authority to secure such access; do any act to secure for himself herself or for any other person access to any computer or any information held in any computer, which he/she has no lawful authority to secure and with the intention of committing an offence under the CCA or any other law;

- Cause a computer to perform any function which will result in unauthorized modification or damage to any computer or computer system or computer program.
- Cause any computer to perform any function which will result in danger to the national security, the national economy or public order;
- Buy, sell, download, upload, copy or acquire the substance or meaning of any information or in any manner deal with any information obtained from a computer or a storage medium of a computer;
- Intercept any subscriber information or traffic data or any communication, to, from or within a computer or any electromagnetic emissions from a computer that carries any information;

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

- Sell, procure for use, import, export, distribute or otherwise make available any device, (including a computer or computer program), computer password, access code or similar information by which a computer is capable of being accessed, with the intent that it be used by any person for the purpose of committing an offence;
- Disclose any information which has been entrusted with, which enables him-her to access any service provided by means of a computer.

Convention on the Suppression of Terrorist Financing Act No. 25 of 2005 and Prevention of Money Laundering Act No. 5 of 2006. Financial Transaction Reporting Act No. 6 of 2006 and the FIU regulations XYZ-TS Personnel shall ensure at all times that they refrain from doing any act through the internet, email or through the Computer Equipment and Information Resources of the Company which will amount to an offence under the above Acts or regulations.

Electronic Transactions Act No.19 of 2006 and Evidence Ordinance of 1995.

Employees should when corresponding with third parties ensure that they do not make any statements or undertakings which may be construed by the other party to infer legal obligations on the company since as per the above Act , an offer, and the acceptance of an offer may be expressed in electronic form and that contract shall not be denied legal validity or enforceability on the sole ground that it is in electronic form whilst the Evidence Ordinance paves the way for computer data to be accepted as evidence in a court of law.

5.37 Independent Review of Information Security

XYZ-TS approach to managing information security and its implementation shall be independently reviewed annually as per the XYZ-TS ISMS internal audit procedure, or when significant changes to the security implementation occur.

Such reviews shall be carried out by an internal/external resource (ISMS Auditor) that shall, at all times, remain independent from implementation of the information security controls.

The results of independent reviews shall be recorded and reported to the ISMC.

5.38 Compliance with Policies, Rules, and Standards for Information Security

ISMC shall regularly review the compliance of security policies, procedures and guidelines. ISMC in its periodic reviews shall consider:

- Causes of Non-Compliance
- Actions to prevent re-occurrence of Non-Compliance
- Review of Corrective Actions

Implementation team shall maintain a record of all the corrective actions. These actions shall be reviewed with specialist and internal/external auditors for improvement in security.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

Only the skilled professionals shall carry out the vulnerability assessments and penetration testing as part of technical compliance checking.

Technical compliance checking shall be undertaken annually and shall cover:

- Hardware Controls
- Software Controls
- Physical security

Utmost care shall be taken when tools are used for technical compliance checking to avoid disruption to business processes.

5.39 Documented Operating Procedures

Operating procedures to enforce all components and requirements of the XYZ-TS Information Security Policy Manual and Supplementary Security Policies shall be maintained and updated by XYZ-TS.

Operating procedures for information systems shall be documented and authorized by the management.

Operating procedures require specifying the instructions for the detailed execution of each job including the interdependencies if any and instructions for dealing with exceptions or errors that may arise during job execution.

6 People Controls

6.1 Purpose

The purpose of this policy is to ensure that XYZ-TS employees, contractors understand their responsibilities, are suitable for the roles they are considered for, and to reduce the risk of human error, theft, fraud or misuse of facilities.

6.2 Responsibility

HR Division: shall be responsible for implementation of the controls and maintenance of all relevant records applicable to employees.

XYZ **Technology Services:** shall be responsible for implementation of the controls and maintenance of all relevant records applicable to XYZ TS contractors and third-party service providers by the respective project leader or team leader.

Policies shall be implemented to address the risks of human error, theft, fraud or misuse of facilities and assist all personnel in creating a secure computing environment.

Please refer ***Human Resource Security Procedure*** (XYZ-TS-IS-PR-015)

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

6.3 Screening

The HR department shall carry out background checks for all staff before the commencement of their employment.

The HR department will maintain a centralized record of all reference checks conducted for new hires. This record will be included in each employee's confidential personnel file.

In addition to reference checks, XYZ - TS may conduct more in-depth background investigations for positions that grant access to sensitive information or systems. The scope and nature of these background checks will be determined based on the level of access and the potential risks associated with the position.

To ensure the security of XYZ - TS operations, XYZ - TS requires reasonable assurance that all third-party vendors and suppliers conduct adequate background checks on personnel assigned to projects of XYZ - TS.

For further details, please refer to the Human Resources Security Procedure.

6.4 Terms and Conditions of Employment

Confidentiality or non-disclosure agreements from all staff, contract staff, contractors, and third-party users reflecting XYZ - TS's need for the protection of information shall be obtained. Non-disclosure of information conditions is included in the standard employment contract with the relevant information security clauses.

The information security responsibilities of end users shall be communicated through the employment contracts and end-user acceptable usage policy.

Employment contracts shall include the “terms and conditions of employment”. The terms and conditions will include:

Requirement in adherence to information security policies and processes of XYZ - TS;

Code of conduct and ethics whilst being employed; and

Actions that will be taken if the employee violates any requirements stated in the employment contract or information security policies.

6.5 Information Security Awareness, Education and Training

The IS Officer, in collaboration with the HR department shall ensure that new joiners undergo mandatory information security training.

The IS Officer, in collaboration with the HR department shall ensure that new joiners undergo mandatory information security awareness sessions at least annually.

The IS Officer shall ensure that periodic information security awareness is provided to all XYZ - TS staff via multiple communication channels.

The information security awareness program will equip employees with the knowledge to protect XYZ - TS’s information and resources through a review of security policies, threats, regulations, controls, and proper use of information systems.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

Information security awareness sessions will be designed to be interactive and promote active participation from attendees. This will include opportunities for feedback, allowing participants to share their insights. By incorporating feedback mechanisms, XYZ - TS can continuously improve the content and delivery of these sessions, maximizing their effectiveness. Attendance records will be maintained for each session to track participation.

6.6 Disciplinary Process

All suspected violations of XYZ - TS's Information Security Policies should be reported promptly.

Suspected information security policy violations shall be promptly escalated to the unit head and department head accordingly. The IS Officer will be notified for escalation as needed based on severity, with HR taking appropriate disciplinary action.

Non-compliance with the policies can result in warnings, or disciplinary proceedings extending to termination of service.

A formal disciplinary process shall be initiated against staff violating laid down information security policies and procedures or perpetrating security breaches as per XYZ - TS's HR disciplinary procedure and records of these shall be kept in the personal file.

For further details, please refer to the HR Disciplinary Procedure

6.7 Responsibilities After Termination or Change of Employment

The HR department shall implement a formal exit process for all XYZ - TS staff, which includes asset return, access revocation, exit interview, etc. The HR department shall maintain adequate records of the entire process.

The HR department, in collaboration with the departing employee and relevant department(s), will perform the exit processes. Upon completion, HR will transmit the departing employee's information to the relevant department(s) to initiate account deactivation and asset return procedures.

During the exit interview process, departing personnel will be explicitly reminded of their continuing obligations under all confidentiality agreements that have been signed with XYZ - TS. This reminder will emphasize that no information obtained during their employment may be disclosed after their departure.

XYZ - TS maintains a strict access control standard, requiring immediate revocation of access rights for staff, contract staff, and service providers upon termination or modification of their employment status.

For further details, please refer to the Human Resources Security Procedure.

6.8 Confidentiality or Non-Disclosure Agreements

Confidentiality agreements shall be signed between parties where any XYZ-TS information exchange is applicable.

The standard agreement template approved by XYZ legal shall be used.

Periodic review shall be carried out to include any potential risks, addressed and documented by XYZ-legal team.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

6.9 Remote Working

Controls shall be established, and appropriate security measures shall be adopted to protect against the risk of information compromise by teleworking. The scope of teleworking shall be defined as XYZ-TS Employees connecting to back-end systems from out of premises through secure connectivity via VPN.

In the event teleworking is required by Contractors and Vendors for an emergency, it shall be granted on a case-by-case basis which will be validated and approved by Head of Governance and Data Protection. Such access and activities carried out during the access shall be monitored and logged.

All teleworking users need to adhere to the Remote Access Policy mentioned in the XYZ-TS Acceptable Usage Policy.

6.10 Information Security Event Reporting

XYZ-TS users shall report information security events as soon as possible to the IT Help Desk.

Types of information security incidents that may include, but are not limited to the following:

- Unauthorized access to XYZ-TS information processing facilities;
- Misuse of information assets;
- Unauthorized disclosure of information;
- Falsification of information;
- Malicious code and hacker intrusion;
- Destruction and damage to information assets;
- Theft-loss-misplace of information, computer equipment or information services;
- Unavailability of critical information asset;
- Installation of equipment not authorized by XYZ-TS; and
- Complaint by a customer or a third party.

Upon receiving the information security incident from the user, respective division heads shall follow the ***IT Incident Management procedure*** (XYZ-TS-IS-PR-011)and self-assign based on the type, nature and severity of the incident.

IT Incident Management procedure (XYZ-TS-IS-PR-011)will include identifying an information security incident, reporting methods, incident classification, escalation matrix and incident management.

XYZ-TS user shall also report any security weaknesses related to systems and services to the information security incident reporting channels in order to prevent such weakness converting into an Information Security Incident.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

XYZ-TS needs to provide ongoing awareness to the users on identifying information security events and reporting such events to the appropriate parties.

Contractors and third parties are also required to inform any information security incident or weakness to the respective project manager or team lead.

7 Physical Controls

7.1 Physical Security Perimeters

XYZ-TS shall have following designated zones based on the sensitivity of information processing.

Security Classification Levels	Areas	Entry Controls
Top Secret	Data Centre-Server room	Bio metric access
Sensitive	All IT Operations Area	Wear XYZ-TS ID tags
Public	General Administration Area	Screened and Cleared at Security point and tag is given to visitors. The tags must be worn at all times.

The perimeter of XYZ-TS's premises containing business information and information processing facilities should be protected by walls-barriers, and appropriate access control mechanisms.

The perimeter controls must ensure sufficient security commensurate with the sensitivity of the information systems.

"Top Secret" areas must be indicated with clear signs (e.g., "Restricted Zone - Authorized Personnel Only").

7.2 Physical Entry

To ensure physical and environmental security of the information processing facility and information assets, XYZ-TS shall maintain an appropriate physical security perimeter and physical entry controls for the XYZ-TS Datacenter.

Access to all critical information processing facilities will be granted in accordance with the access control procedures. Such access will be logged, securely maintained and regularly reviewed by XYZ-TS.

"Top Secret" and "Sensitive" areas must have a physical access control mechanism implemented, which allows only specific authorized persons to enter, and must be suitable for the type of area being secured. This may include automated access control devices (biometric devices, proximity card devices, etc.) or suitable lock and keys.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

All employees of XYZ-TS are authorized to access the "Public" area. However, only specifically authorized employees may enter "Top Secret" and "Sensitive" areas other than as visitors.

Authorization to enter "Top Secret" and "Sensitive" areas are to be granted only when there is a business or technical reason for the person to enter the premises. Authorization to access "Top Secret" and "Sensitive" areas must be approved by authorized personnel.

Visitor access to "Top Secret" and "Sensitive" areas where sensitive information (digital or printed) or information systems are located, should be escorted by an internal staff member.

Physical access rights must be revoked immediately upon termination - resignation of employees or completion of a consultation or vendor agreement.

For server room security, names of the approved individuals shall be included in the Authorized Personnel list and shall be maintained by the Manager Infrastructure and Support Services

Unauthorized access into the data center and-or violation of this policy must be reported to CDO, with the date and time and name of person(s) causing the violation or the information security incident.

A record of visitor access to "Top Secret" and "Sensitive" areas must be maintained for each location. The records must at minimum contain name and identification of the visitor (employee number, National ID number - passport number), date and time of entry, reason for the entry, date and time of exit, and name and employee number of authorized employee escorting the visitor. These records may be automated (i.e., logs of access control device), manual (i.e., log book), or a combination of both.

External agencies' access such as courier and delivery services shall be restricted to designated delivery- collection points.

Delivery and loading areas, as well as other publicly accessible areas shall be appropriately isolated from information assets and information processing facilities.

7.3 Securing Offices, Rooms, and Facilities

XYZ-TS shall ensure that sensitive and-or critical information processing facilities are appropriately equipped and maintained with security controls to safeguard the information contained within the facility against manmade or environmental threats.

7.4 Physical Security Monitoring

XYZ - TS shall ensure that the premises are continuously monitored for unauthorized physical access through technical and process controls.

For further details, please refer to the ***Physical and Environmental Security Procedure***

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

7.5 Protection Against Physical and Environmental Threats

7.5.1 Protection from External Threats

Physical safety of personnel must take precedence in any circumstance and must not be compromised in achieving any other policy objective.

XYZ-TS must adhere to all health and safety rules and regulations imposed by the Government and other applicable regulatory bodies.

Where possible, manned security points shall be implemented at “To Secret” and “Secret” area entry points.

CCTV monitoring systems shall be implemented for the above zones. CCTV recording shall enable XYZTS to provide evidence during an information security incident investigation.

7.5.2 Protection from Fire

Fire detection and extinguishing equipment must be placed and must be adequate in order to protect critical business processing equipment. They should be located near critical equipment for easy access.

XYZ Capital Administration division is responsible for the selection and maintenance of all fire detection and extinguishing equipment at XYZ-TS premises.

Maintenance work of fire detection and suppression equipment must be carried out by persons with required expertise. Frequency of maintenance must be as stipulated by the equipment supplier. Instructions on use of fire extinguishers must be placed close to each fire extinguisher.

Hazardous or combustible materials should not be kept in or around sensitive areas (e.g., Datacentres, server room, UPS room, etc). If such material is to be stored in the same premises, they must be kept at a safe distance from the sensitive areas. Fire extinguishers of an appropriate type must be in close proximity to such material.

Appointed fire marshals must be trained in the use of all fire extinguishing equipment available to them. The training frequency must not be less than annually.

All employees are responsible to educate themselves on the use of fire equipment and fire safety procedures and must seek advice and instructions from the Administration division whenever required.

7.5.3 Protection from Water Damage

All IT equipment must be sited to prevent water damage, such as from floods, rain, plumbing defects, etc. Safeguards may include raised floors - keeping equipment on elevated platforms as well as premises design safeguards such as proper drainage systems.

7.5.4 Power, Air-conditioning, and Other Supporting Utilities

All IT equipment must be maintained in conditions within which suppliers warranty continues to be applicable. Whenever applicable, all systems must be maintained as per the guidelines (with regard to power supply, humidity, ventilation, temperature control, etc.) provided by the supplier.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

The power supply system of XYZ-TS premises must be implemented to provide the required level of safety and continuity. The implementation of the fire suppression system, air-conditioning, and other critical systems must be taken into consideration when designing the power supply system.

All critical IT systems (including server, network equipment, and workstations) must have sufficient protection for power failures including power loss, voltage anomalies, etc. Protection measures may include a combination of Uninterruptible Power Supply (UPS) devices and generators. The protection measures must be appropriate with the local main power supply conditions at each location.

All power supply equipment of XYZ-TS must be tested and maintained regularly as per the guidelines of the relevant equipment manufacturer. The safeguard and maintenance of such equipment is the responsibility of the building maintenance.

Whenever the IT equipment requires regulation of air temperature (e.g., for servers), the air-conditioning system to that area must be supplied with uninterruptible power.

Environmental conditions affecting proper functioning of the IT equipment (such as air temperature and humidity in the server room) must be regularly monitored by the relevant process owners. If any adverse condition is detected, immediate steps must be taken to avoid data loss and system failure. When evaluating the environmental factors, the equipment and system suppliers' guidelines must be taken into consideration.

7.6 Working in Secure Areas

Working guidelines shall be given for "Top Secret" and "Sensitive" areas which shall be followed by all the XYZ-TS employees.
All visitors working in "Top Secret" and "Sensitive" areas must be under supervision of a person with authorization for that zone. This is especially applicable for maintenance and cleaning work carried out within "Top Secret" and "Sensitive" areas by external parties.

Vacant "Top Secret" and "Sensitive" areas must be locked and periodically checked by authorized personnel.

7.7 Clear Desk and Clear Screen Policy

Documents containing confidential organizational information should be stored in a safe and secure place.

Every employee should ensure that whenever they leave their desk, they lock their screen and clear all documents from their respective desks.

The white boards- flip charts used by the users shall also be cleared and no critical information shall be left on the boards - flip charts.

Sensitive information shall be turned over or shall be put out of sight when visitors are present.

XYZ | XYZ Only
CS5292 W6 · D04 · sanitised for teaching

Remember that it is a fundamental principle that knowledge or possession of sensitive information is to be strictly limited to those users that have a need to know and appropriate privileges; XYZ-TS users are to adhere to this principle.

All employees must follow XYZ-TS clear desk and clear screen policy instructions.

7.8 Equipment Siting and Protection

Network devices such as routers, servers, network cables, switches, and hubs must be placed in "Top Secret" area that provides protection from unauthorized or unnecessary access.

All data storage devices and backup equipment must be kept in designated secure areas and must not be kept in "Public" area.

7.9 Security of Assets Off-Premises

XYZ-TS management shall ensure that no storage media containing XYZ-TS information will be sent off premises (outside XYZ-TS premises) without any approval and shall for the gate pass process.

7.10 Storage Media

Equipment used to support business activities outside XYZ-TS must be subject to the same type of management authorization and security protection as that of on-site equipment.

No person is allowed to remove any IT equipment (including workstations, peripherals, and storage media) from XYZ-TS premises without approval by the CDO. Respective asset owner must maintain a register of all equipment approved for removal from XYZ-TS premises indicating the person responsible for the equipment, timeframe approved for removal and reasons for removal.

Removal of data storage devices or equipment with data storage devices must be approved by the CDO.

The CDO must ensure that all equipment removed from XYZ-TS custody for maintenance purposes are properly secured and sanitized to prevent unauthorized access to information kept in such equipment.

Policies shall be implemented to ensure the secure handing of media and disposal.

Refer ***Media Handling and Disposal Procedure*** (XYZ-TS-IS-PR-006)

7.11 Supporting Utilities

Adequate mechanisms shall be implemented to protect equipment from power failures and other disruptions caused by failures in supporting utilities. (i.e. Uninterrupted Power Systems and Generators).

7.12 Cabling Security

Network and power cabling should be protected and secured from unauthorized interception and damage. Whenever possible, cabling must be made underground or alternatively within a secured housing.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

Cable and equipment markings and naming should be clearly identifiable and should be documented for reference and to avoid errors or mistakes.

A network cabling diagram must be maintained by the NOC Team.

Network cabling diagram should separate from power cabling.

7.13 Equipment Maintenance

Equipment should be maintained periodically according to vendor specifications and service intervals.

The maintenance of equipment should be carried out by authorized personnel only. XYZ-TS must ensure that maintenance is carried out by persons with necessary technical competency. XYZ-TS must also ensure the sufficiency of procedures for the safety of equipment and data during maintenance work.

Records of equipment failures during maintenance should be kept, along with the remedial measures executed to rectify the failure. The records should include the names and identification of the personnel who took part in the maintenance routine.

7.14 Secure Disposal or Re-Use of Equipment

All items of equipment containing storage media shall be verified to ensure that any sensitive data and licensed software has been removed or securely overwritten prior to disposal or re-use.

8 Technological Controls

8.1 User Endpoint Devices

The usage of the mobile devices within the XYZ-TS network or connected to XYZ-TS network is subject to XYZ-TS *Acceptable Usage Policy*, which articulates the detailed Mobile Device Policy.

Controls shall be established, and appropriate security measures shall be adopted to protect against the risks of information compromise by using mobile computing and communication facilities.

Equipment such as personal computers, servers, terminals and other devices shall be protected from unauthorized use and-or access when unattended.

Appropriate security measures such as password protected people savers and-or screen or key locks, automated termination of active sessions shall be adopted to protect the unattended equipment.

8.2 Privileged Access Rights

The privileges associated with each information system (e.g., for each operating system or application) and assigned to each user shall be identified.

Privileges shall be allocated to individuals on "need-to-use" and “need-to-know” basis.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

All privileged access shall be logged and reviewed as appropriate according to the relevant statutory, regulatory, legal, and contractual requirements.

For further details, please refer to the System Access Control Procedure

8.3 Information Access Restriction

Access to application systems and information shall be restricted to authorized users only. The access restrictions shall be balanced in such a way that appropriate protection is provided for application and information while the business process continues smoothly. Password Management System

Procedures for enforcing and managing the user passwords shall be established and implemented to ensure user's identity and authenticity in accessing information resources. Following password policy shall be configured in the system.

8.3.1 XYZ-TS Password Policy – User Level Password Policy

Following **minimum** password standard shall be used for all system level, domain level and application-level user passwords. Password policy shall be implemented in all the systems-applications and infrastructure where possible. Any exceptions to the password policy or if this cannot be technically enforced, such situations shall be documented, risk assessment and risk treatment shall be carried out accordingly.

Password Setting	Configuration for information processing facilities where logical access required
Minimum number of characters	***10 characters***
Enforcing password complexity	***Enabled***
Maximum password age	***60 days***
Minimum password age	***1 days***
Enforcing password history	***5 previous passwords***
Account lockout threshold	***10 invalid logins***

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

8.3.2 XYZ-TS Password Policy – Administrative Level Password Policy

Following minimum password standard shall be used for all system level, domain level and application level administrative passwords. And All systems integrated with Privileged Access Management (PAM) will adhere to the established PAM password policy

Password Setting	Configuration for information processing facilities where logical access required
Minimum number of characters	***16 characters***
Enforcing password complexity	***Enabled***
Maximum password age	***42 days***
Minimum password age	***1 days***
Enforcing password history	***24 previous passwords***
Account lockout threshold	***10 invalid logins***

8.3.3 XYZ-TS Password Policy – Exemptions

Below mentioned systems are not aligned with the XYZ-TS password policy due to technical incapability to integrate with the XYZ-TS recommended, AD Authentication mechanism.

#	System Name	Description	System Owner
1	SysAid	Corporate Helpdesk system	Infrastructure Support

8.4 Access to source code

Adequate access control procedures shall be defined and established to authorize access to the program source codes.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

8.5 Secure authentication

A general notice or warning shall be displayed for end-user devices, specifying that the devices shall be accessed only by authorized users.

Secret authentication information (e.g., password, PIN, OTP), shall be masked while being entered into the systems.

All users shall be required to keep personal secret authentication information confidential.

The exchange of temporary secret authentication information shall be carried out securely.

All passwords shall be generated and used as per the formal password management practices of XYZ - TS.

Default vendor secret authentication information shall be changed or disabled before migration into the production environment.

For further details, please refer to the Password Management Procedure

8.6 Capacity Management

Capacity management shall be carried out by respective division heads for their information assets considering the current utilization and future capacity requirements following the ***IT systems Capacity & Performance management procedure*** (XYZ-TS-IS-PR-013). This includes capacity management for the following (not limited to):

- Hardware resources;
- Software licensing;
- Network bandwidth;
- Workstations;
- Storage;
- Processing;
- Data center space; and
- Personal or human resources.

The performance of critical information processing and communication facilities shall be monitored.

The performance monitoring reports shall be analyzed, and any bottlenecks shall be identified. For each new and ongoing activity, capacity requirements shall be identified. System tuning and monitoring shall be carried out to ensure and, where necessary, improve the availability and efficiency of systems.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

Potential bottlenecks that might present a threat to the system or services are identified and appropriate actions are planned.

8.7 Protection Against Malware

8.7.1 Detection

The symptoms of malicious software infections include a considerably slower response from the system, inexplicable loss of data, erroneous change in file dates, increase or decrease in file size, or total failure of the computer system.

End users shall report these kinds of abnormal behaviors of the system, immediately to the IT help desk. IT help desk will follow ***IT Incident Management Procedure*** (XYZ-TS-IS-PR-011) to respond to the incident. **Protection and Treatment.**

It shall be ensured that the anti-virus software is installed and active on every machine. The configuration of anti-virus software shall be protected to avoid any unauthorized modifications.

Updating of anti-virus software on all desktops shall be managed centrally.

Systems shall be implemented to review the anti-virus software activity - logs, to check whether antivirus software is running regularly on respective computers.

Controls shall be implemented to protect the network from spyware software.

The Anti-Virus software for messaging system (e-mail) shall be implemented. If the virus is found in mail attachment file, this file shall be deleted and the sender will be informed. The recipient would get the remaining message.

Users shall be regularly updated about the latest information on malicious code through circulars, internal magazines or IT communications etc.

Unauthorized or any pirated software shall not be used by the XYZ-TS employees.

Any files or data obtained from outside through any media required for business, shall be tested for virus before being used.

Appropriate recovery procedure shall be in place for recovering from malicious code attacks, including all necessary data and software back-up and recovery arrangements.

Necessary procedural protection shall be taken to protect against the introduction of malicious code during maintenance and emergency procedures, which may bypass normal malicious code protection controls.

8.7.2 Employee Responsibility

XYZ-TS Personnel should ensure that their machines are kept virus-free by actions such as not opening e-mail attachments from unknown sources.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

8.8 Management of Technical Vulnerabilities

To minimize the risks from operating system changes, business-critical applications and systems shall be reviewed and tested to ensure that there is no adverse impact on the organizational operations or security of those applications or operating systems.

Adequate responsibilities shall be established within the organization for implementing and monitoring vulnerabilities and vendor's release of patches and fixes.

XYZ-TS shall establish a technical vulnerability management process with defined frequencies and a scope. These will include but not be limited to

- External penetration testing for internet-facing servers;
- Internal penetration testing for critical application servers;
- Web application penetration test (if required); and
- Firewall configuration reviews.

Timely information about technical vulnerabilities of information systems shall be obtained by Head of Security & Head of Governance & Data Protection via the special interest groups and communicated to relevant information asset owners.

XYZ-TS's exposure to such vulnerabilities shall be evaluated, and appropriate countermeasures will be defined and implemented in a timely manner, to address the associated risks.

8.8.1 Patch Management

All system components directly associated with XYZ-TS data environment must be securely hardened and configured with all necessary and appropriate patches and system updates for preventing the exploitation or disruption of mission-critical services. All patch releases will follow a defined process for patch deployment that includes assessing the risk, testing, scheduling, installing and verifying.

Patch Management will consist of:

Subscribing to industry-leading security sources, additional supporting resources for vulnerability announcements and other security patch management alerts and issues

Procedures for establishing priorities regarding Security Patch Management.

This will include, but is not limited to;

- the significance of the threat,
- the existence and the overall threat of exploitation and
- the risks involved in applying Security Patch Management procedures (its effect on other systems, available resources, and constraints).

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

Procedures for the deployment, distribution, and implementation of patches and other related security hardening procedures

Process owners shall verify that the patches are tested and successfully deployed.

8.9 ICT Configuration Management

The TechSecOps shall ensure that all critical network and server infrastructures are reviewed independently based on the best practices.

The review should be recorded, and a log should be maintained of all configuration changes for all critical network and server infrastructure.

The TechSecOps shall document and maintain secure configuration for different technologies that are in sure and ensure the systems are configured according to the same.

The review should be recorded, and a log should be maintained of all configuration changes for all critical network and server infrastructure.

Any changes to the existing configuration of critical network, server, and application infrastructures shall follow the existing change management process.

8.10 Information Deletion

Sensitive information should be deleted when it is no longer required in a secure method. The information must be deleted in a secure method and the results of deletion must be recorded for evidence of the information deletion.

8.11 Data Masking (N/A)

Based on the legal and regulatory requirements or any other contractual obligations, critical data must be masked. If any sensitive information is being used in any information system, appropriate masking strategies shall be used to prevent information disclosure.

8.12 Data Leakage Prevention

"A data leakage prevention (DLP) strategy has been implemented, managed internally using a tool, and is regularly updated to meet the TS's evolving requirements."

8.13 Information Backup

Information asset owners are responsible to maintain an appropriate backup plan and schedule for their respective information assets as per the business requirements and following the XYZ-TS *Backup and Recovery Procedure* (XYZ-TS-IS-PR-010).

Onsite and offsite backup storage sites shall be appropriately protected.

8.14 Redundancy of information processing facilities

XYZ-TS shall implement High Availability (HA) solutions for business-critical information assets to ensure continued services.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

8.15 Logging

System administrator shall maintain Operational and Maintenance logs of all activities.

The logging shall be automated as far as possible. Implement automatic recording of logs wherever feasible as it is useful to maintain integrity of the logged information. Logs shall include but not limited to;

- Date, time and other details of key events, e.g. log-on and log-off
- Records of successful and rejected system access attempts
- Changes to system configuration
- Use of privileges
- Fault Logging

Users must report to the XYZ-TS of all incidents in which the system is unable to function as required.

XYZ-TS must maintain a complete log of all reported faults (which is separate and different from the change request log), reported by user, third parties, or discovered in any other manner. The fault log must include nature of fault, affected systems, identified cause, and corrective measures taken.

System error logs and solutions provided shall be reviewed periodically.

8.15.1 Review of Logs

System - Network administrator shall review the logs alerts that are generated via the SIEM and other monitoring tools in real time to initiate timely actions for system or network errors. Regular review of the logs is essential to maintain maximum uptime of the system, which leads to continuity of business process.

8.15.2 Monitoring System Use

System Administrator shall monitor the use of information systems to safeguard the information from unauthorized activities and act upon the receipt of alerts from the systems.

Level of monitoring shall be determined by risk assessment of individual systems.

Logs shall be protected from unauthorized accesses and changes.

Logs shall be backed up daily. These logs shall be archived quarterly for all critical systems.

The log retention period shall be determined based on business needs, legal, statutory and contractual obligations.

All activities of system administrator - system operator shall be logged and reviewed.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

8.16 Monitoring Activities

The TS shall ensure that all critical networks, servers, and application infrastructure are monitored for anomalous behavior and appropriate actions should be taken to evaluate potential information security/ cyber security incidents.

8.17 Clock Synchronization

The correct setting of computer clocks is important to ensure accuracy of logs. The logs may be required for investigations or as evidence in legal or disciplinary process.

All information systems and devices wherever applicable, which have real time clocks, shall be set to [country] local Standard Time Zone (local time).

Systems administrator shall regularly check and maintain the clocks using an NTP server as per standard time settings as mentioned above.

8.18 Use of Privileged Utility Programs

Most operating systems have one or more system utility programs and commands that might be capable of overriding system and application controls. The use of such critical system utilities and Operating System (OS) commands shall be tightly controlled by not allowing privileged access of the OS to users who do not need it.

8.19 Installation of Software on Operational Systems

To minimize the risk of corruption to the operational systems, the procedures shall be in place to control the installation of software.

The business requirements for the change shall be taken into account before upgrading software to a new release.

The risks and severity of security problems affecting new version shall be considered before change or maintenance.

Updates to operational software, applications, and program libraries shall only be performed by appropriately trained personnel following management authorization.

Applications and operating system software should only be implemented after extensive and successful testing; the tests may include tests on usability, security, effects on other systems and user-friendliness, and should be carried out on separate systems (non-production environment).

A roll back strategy shall be in place prior to implementing changes to production environment.

Rules governing the installation of software by users shall be established and implemented.

The organization shall define and enforce strict policy on which types of software users may install.

The principle of least privilege shall be applied. If granted certain privileges, users may have the ability to install software. The organization should identify what types of software installations are permitted

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

(e.g. updates and security patches to existing software) and what types of installations are prohibited (e.g. software that is only for personal use and software whose pedigree with regard to being potentially malicious is unknown or suspect). These privileges shall be granted having regard to the roles of the users concerned.

8.20 Network Security

Appropriate logical and physical security measures and features shall be implemented to protect the network.

Network and System Engineers must establish appropriate controls to prevent unauthorized access that could impact critical business information assets within the network and connected services.

Controls must be implemented to protect connected systems, and to safeguard the confidentiality and integrity of critical business information assets that pass over public networks.

Appropriate network security requirements must be covered by the Service Level Agreements (SLA) with external parties.

8.20.1 Access to Network Infrastructure and Utilities

Logical access to networking hardware and software must be limited to properly authorized personnel.

Access to programmable network devices (e.g., routers, switches and bridges) must be restricted to authorized IT staff.

The use of network diagnostic and security tools must be limited to specifically designated staff, and in accordance with their job responsibilities.

Access to all network configuration and security-related data, must be limited to authorized users.

8.20.2 General Network Management Controls

Network infrastructure devices must be configured to prevent the disclosure of the configuration of the internal network to external entities.

Unattended network connection ports (e.g., conference rooms, empty offices, etc.) must be enabled only when needed, and must be blocked at all other times.

Any services that are not required must be blocked, preferably at the firewall, and where possible, also at the end system or server.

Users must only be provided with direct access to the services that they have been specifically authorized to use.

8.20.3 Network Infrastructure Management Controls

The network administrators shall request permission via change request from the Governance Team and SOC Team prior to performing any alteration on XYZ-TS network security standards.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

Governance Team and SOC Team shall approve/ any modification on XYZ-TS network prior to implementation.

The network administrators shall maintain a record pertaining to a network security change including but not limited to the request, approval, rejection, reasons, etc.

The network administrators shall maintain an updated network diagram.

8.21 Security of Network Services

XYZ-TS shall regularly monitor the ability of the network service providers to manage agreed services in a secure manner.

The security arrangements necessary for particular services, such as security features of network services, service levels, and management requirements, should be identified where necessary. XYZ-TS shall ensure that network service providers implement these measures.

8.22 Segregation in Networks

XYZ-TS shall segregate the network to isolated networks to prevent unauthorized access.

Network shall be appropriately segregated using an appropriate mechanism.

User access to production servers shall be restricted to the presentation layer of the applications and based on known application ports.

8.23 Web filtering

Access to Malicious / unauthorized websites shall be blocked from the corporate network. Downloading from unverified or untrusted websites shall be restricted.

8.24 Use of Cryptography

Based on the business need, cryptographic controls shall be identified and implemented to provide appropriate level of protection to information and information systems.

Adequate process or procedures on the use of cryptographic controls for protection of information shall be developed and implemented. When developing the procedures or process, consideration shall be given to:

- Approach towards the use of cryptographic controls across the organization;
- Rules under which the business information is protected;
- Required level of protection be identified after adequate risk assessment;

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

- Required methods of protections of cryptographic keys and recovery methods in case of loss of or damage to those keys;
- Roles and responsibilities of the personnel for implementation, management and generation of keys; and
- Relevant laws and legislation, shall be considered while using digital signatures.

All cryptographic keys shall be protected against modification, loss, destruction and unauthorized disclosure. A process or procedure shall be put in place for:

- Generating keys for different systems and applications;
- Generating and obtaining public key certificates;
- Distribution of keys to the intended users;
- Storing and archiving or back-up of the keys;
- Changing or updating the rules on keys when there is need;
- Handling on compromised keys while they are in transit or in storage;
- Recovery of damaged-corrupted or lost keys for recovery of encrypted business information and;
- Effective management of use of cryptographic key techniques during its life cycle.

8.25 Secure Development Life Cycle (N/A)

The TS shall establish and appropriately protect secure development environments for system development and integration efforts that cover the entire system development lifecycle.

For further details, please refer to the Secure Development Lifecycle Procedure

8.26 Application Security Requirements

Any application services that will be hosted on public servers or communication involved in passing information over public networks shall undergo thorough vulnerability assessments, penetration testing, and quality assurance to ensure the adequacy of controls to mitigate threats applicable to such applications.

Internal and external software development teams are responsible for the remediation of identified vulnerabilities.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

TS shall ensure information involved in application service transactions is protected using adequate controls to prevent incomplete transmission, misrouting, unauthorized message alteration, unauthorized disclosure, unauthorized message duplication, or replay.

8.27 Secure System Architecture and Engineering Principles (N/A)

Secure system architecture and engineering principles are foundational to developing robust and secure IT systems. TS develops processes with the key principles when designing and implementing secure system architecture such as Least Privilege, Separation of Duties, Secure Coding Practices, Secure Configuration Management, and Auditing and Monitoring.

8.28 Secure Coding (N/A)

The TS shall ensure that the secure coding best practices shall be defined by the IS Officer. The secure coding best practices shall be integrated into the software development process.

The TS shall ensure that all outsourced development follows the secure coding best practices and this shall be incorporated into the outsourced agreements as a requirement.

8.29 Security Testing in Development and Acceptance

For all the new information systems, upgrades to existing systems or new versions, acceptance criteria shall be clearly defined prior to testing and shall be approved by the business owners.

System shall not be allowed to release to the production until the testing is complete and user sign off obtained for all the test results.

The Head – Information Security shall be consulted in order to define the criteria relating to information security.

A detailed checklist shall be prepared for various parameters to be incorporated in the acceptance test.

The acceptance criteria can be based on process requirements and-or user requirements.

8.30 Outsourced Development

Wherever the software development is outsourced, the development shall be supervised and monitored. Adequate procedures or process shall be in place for licensing agreements, code ownership, and intellectual property rights, quality assurance on the software developed, testing before implementation etc.

8.31 Separation of Development, Test, and Production Environments

Development, testing, and operational facilities shall be separated to reduce the risks from unauthorized access or (inadvertent) changes to the operational systems where applicable.

Rules for the transfer of software from development to operational status shall be defined and documented.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

Users shall use different user profiles for operational and test systems, menus shall display appropriate identification messages to reduce the risk of error, and sensitive data shall not be copied into the test system environment.

The TS shall establish and appropriately protect secure development environments for system development and integration efforts that cover the entire system development lifecycle.

8.32 Change Management

Formal management responsibilities and procedures shall be in place to ensure satisfactory control of all changes to equipment, operating systems, , and procedures are required to be followed.

Changes to infrastructure shall be duly approved before implementation and a risk assessment shall be carried out.

A ticket shall be raised in Change management system for each scheduled, unscheduled or business critical change following the steps contained in the XYZ-TS ***change management procedure***.

A change review shall be completed for each change, whether scheduled or unscheduled, and whether successful or not.

A change management log shall be maintained for all changes. The log must contain, but not limited to:

- Date of submission and date of change
- Owner and custodian contact information
- Identification and nature of the change
- Indication of success or failure
- Communication of change details to all relevant parties
- Fall back procedures for aborting and recovering from unsuccessful changes

Modifications to purchased software shall be restricted.

8.33 Test Information

The use of operational databases containing personal information or any other sensitive information for testing purposes shall be avoided.

The following shall be applied to protect operational data when used for testing purposes.

The access control procedures which apply to the production environment, shall also apply to the testing environment (test application systems)

The authorization procedure shall be followed for each time whenever operational information is copied to test application system

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching

In case of sensitive data is used it should be sanitized to prevent loss of confidentiality.

The operation/production data shall be erased after its use from the testing application system; and

Logs of production system data copying to testing systems shall be maintained.

For further details, please refer to the System Access Control Procedure

8.34 Protection of Information Systems During Audit Testing

ISMC shall define the scope of information systems audit and identify resources required for performing it.

Persons carrying out the audit shall have proficiency in audit and will be independent of the work to be audited.

All access to information and information systems provided to auditors shall be read only.

9 Version History Control

It is the responsibility of ISMS Security Policy holders to ensure that additions and amendments are inserted into the ISMS Manual whenever change occurs and the copies of superseded policies, procedures or documents are discarded.

Master copies of superseded documents are secured by the ISO as archive for future reference.

The numbering system will be as per the XYZ-TS ***Mandatory ISMS Procedures*** (XYZ-TS-IS-PR-002).

10 Non-adherence and Disciplinary Action

All violations and attempted violations of the XYZ-TS Information Security Policy by the employees of XYZ-TS shall result in disciplinary action instituted by Human Resources (HR) Division in consultation with the Information Security Management Committee (ISMC) wherever appropriate.

All violations and attempted violations of the Information Security Policies by third party service providers shall result in appropriate action being instituted in terms of the terms and conditions of the agreements entered with such service providers.

All violations of the Information Security Policies must be reported to the CDO.

XYZ | XYZ Only

CS5292 W6 · D04 · sanitised for teaching